

Matriz de Evaluación PRAGMATIC Completa – Indicadores MITRE ATT&CK

Escala PRAGMATIC: 0 (nulo) a 5 (excelente).

Objetivos nacionales inspirados en estrategias de resiliencia y panoramas de ENISA ETL 2025.[web:66]
[web:43]

Indicador 1 – Cobertura de tácticas ATT&CK prioritarias

GQM

- Goal: Aumentar la resiliencia nacional frente a las tácticas de ataque más frecuentes y dañinas en Europa y en los sectores críticos nacionales.[web:66][web:61]
- Questions:
- Q1.1: ¿Qué tácticas ATT&CK son prioritarias para el país y por sector?
- Q1.2: ¿Qué porcentaje de estas tácticas dispone de capacidades de detección declaradas en las organizaciones críticas?
- Q1.3: ¿Cómo evoluciona este porcentaje en el tiempo?
- Metric:
- M1: $\% \text{Cobertura_Tácticas_Prioritarias} = (\text{N}^{\circ} \text{ tácticas prioritarias con detección declarada} / \text{N}^{\circ} \text{ total tácticas prioritarias}) \times 100$.

PRAGMATIC

Criterio	Puntuación	Justificación breve
Predictivo	4	Anticipa reducción de probabilidad de intrusiones graves si aumenta la cobertura.
Relevante	5	Directamente alineado con objetivos nacionales de resiliencia.
Accionable	4	Permite focalizar inversiones en tácticas descubiertas como “en rojo”.
Genuino	3	Depende de auto-declaración; requiere mecanismos de validación.
Significativo	4	Entendible por decisores (porcentajes de cobertura sobre tácticas “de moda”).
Preciso	3	Precisión media; hay que definir bien el conjunto de tácticas prioritarias.
Oportuno	4	Se puede actualizar anualmente o semestralmente.
Independiente	3	Correlaciona con cobertura de técnicas, pero aporta vista táctica agregada.
Rentable	4	Coste moderado si se integra en reporting estándar de organizaciones críticas.

Indicador 2 – Cobertura de técnicas ATT&CK relevantes

GQM

- Goal: Garantizar que las organizaciones críticas disponen de detecciones activas para las técnicas ATT&CK más relevantes para su sector.[web:29][web:66]
- Questions:
 - Q2.1: ¿Qué técnicas ATT&CK son relevantes para cada sector según CTI, ENISA y experiencias propias?[web:66][web:61]
 - Q2.2: ¿Qué porcentaje de estas técnicas está cubierto por detecciones (reglas, firmas, lógicas)?
 - Q2.3: ¿Cómo varía la cobertura entre sectores y tamaños de organización?
- Metric:
 - M2: $\% \text{Cobertura_Técnicas_Relevantes} = (\text{N}^{\circ} \text{ técnicas relevantes con detección configurada} / \text{N}^{\circ} \text{ total técnicas relevantes}) \times 100$.

PRAGMATIC

Criterio	Puntuación	Justificación breve
Predictivo	5	Alta; correlaciona con capacidad de detectar ataques reales.
Relevante	5	Directamente ligada a capacidad de defensa técnica.
Accionable	5	Indica qué técnicas deben priorizarse en nuevos casos de uso.
Genuino	3	Requiere revisión de calidad de las detecciones (no sólo existencia).
Significativo	4	Potente para SOC y responsables técnicos; requiere traducción para negocio.
Preciso	4	Puede definirse de modo robusto si se fijan listas por sector.
Oportuno	3	Actualización trimestral o anual razonable.
Independiente	3	Relacionada con indicador 1, pero aporta nivel técnico más granular.
Rentable	3	Puede ser costosa sin herramientas; más rentable si se automatiza (heatmaps, etc.). [web:23]

Indicador 3 - Brecha cobertura declarada vs cobertura validada

GQM

- Goal: Reducir la discrepancia entre la cobertura de detección declarada y la realmente observada en ejercicios y incidentes.[web:16][web:22]
- Questions:
 - Q3.1: ¿Qué técnicas se declaran cubiertas en políticas y diseños?
 - Q3.2: ¿Qué técnicas se verifican efectivamente en ejercicios de emulación y análisis de incidentes?
 - Q3.3: ¿Cuál es la brecha media por técnica/táctica y sector?
- Metric:
 - M3: $Brecha_Cobertura = \%Cobertura_Declarada - \%Cobertura_Validada$, positiva si declaramos más de lo que realmente vemos.

PRAGMATIC

Criterio	Puntuación	Justificación breve
Predictivo	4	Indica riesgo de falsa sensación de seguridad.
Relevante	5	Crucial para supervisores nacionales y reguladores.
Accionable	5	Señala dónde hay que ajustar detecciones o revisar diseños.
Genuino	4	Basada en datos de ejercicios e incidentes; buena base de realidad.
Significativo	4	Mensaje claro (“sobre-prometemos, sub-cumplimos”) para la alta dirección.
Preciso	3	Precisión media; depende de calidad de los ejercicios.
Oportuno	3	No necesita alta frecuencia (anual o bienal).
Independiente	4	Complementa indicadores de cobertura, mostrando la “mentira piadosa” implícita.
Rentable	3	Depende del coste de ejercicios/purple teaming.

Indicador 4 – Calidad de detección (falsos positivos / contexto)

GQM

- Goal: Mejorar la calidad de las detecciones etiquetadas con ATT&CK reduciendo falsos positivos y aumentando el contexto útil para el analista.[web:16][web:60]
- Questions:
 - Q4.1: ¿Cuál es la tasa de falsos positivos para las técnicas más importantes?
 - Q4.2: ¿Disponemos de contexto suficiente (usuario, host, proceso, TTP) en las alertas?
 - Q4.3: ¿Cómo afecta esta calidad al tiempo de investigación y resolución?
- Metrics:
 - M4a: Tasa_Falsos_Positivos = N° alertas falsas / N° total alertas para la técnica.
 - M4b: %Alertas_con_Contexto_Completo (definir campos mínimos).

PRAGMATIC

Criterio	Puntuación	Justificación breve
Predictivo	3	Menos directo que cobertura, pero anticipa fatiga y errores.
Relevante	4	Importante para eficiencia del SOC.
Accionable	5	Lleva directamente a tuning, mejora de reglas y automatización.
Genuino	4	Basado en datos operativos reales.
Significativo	3	Más técnico; requiere traducción para niveles ejecutivos.
Preciso	4	Definible con claridad en herramientas modernas. [web:16][web:23]
Oportuno	4	Puede medirse mensualmente/trimestralmente.
Independiente	3	Correlaciona con tiempos de respuesta, pero foco en calidad.
Rentable	3	Requiere extracción de datos, pero factible si se automatiza.

Indicador 5 – Porcentaje de alertas críticas etiquetadas con ATT&CK

GQM

- Goal: Asegurar que las alertas críticas disponen de un contexto ATT&CK que permita análisis, agregación y reporte comparables.[web:29]
- Questions:
- Q5.1: ¿Qué porcentaje de alertas de severidad alta/crítica están etiquetadas con Táctica/Técnica ATT&CK?
- Q5.2: ¿En qué medida esto permite análisis transversales y comparativos?
- Metric:
- M5: $\% \text{Alertas_Críticas_Tag_ATTCK} = (\text{N}^\circ \text{ alertas críticas con etiqueta ATT\&CK} / \text{N}^\circ \text{ total alertas críticas}) \times 100$.

PRAGMATIC

Criterio	Puntuación	Justificación breve
Predictivo	2	Más descriptivo que predictivo.
Relevante	3	Ayuda a informes nacionales y comparaciones.
Accionable	4	Motiva cambios en herramientas/procesos de etiquetado.
Genuino	4	Depende de cómo se etiquete, pero refleja práctica real.
Significativo	3	Útil para CTI y analistas; menos intuitivo para negocio.
Preciso	4	Fácil de definir y medir.
Oportuno	4	Puede medirse con alta frecuencia (mensual).
Independiente	3	Relacionado con cobertura, pero centrado en metadatos de alertas.
Rentable	4	Bajo coste si las herramientas soportan ATT&CK de forma nativa.[web:23][web:16]

Indicador 6 – MTTD, MTTC, MTTR por táctica/técnica crítica

GQM

- Goal: Reducir el tiempo de detección, contención y recuperación de incidentes para las tácticas/técnicas ATT&CK que causan mayor impacto (p. ej., credenciales, movimiento lateral, exfiltración, impacto).[web:26][web:66]
- Questions:
 - Q6.1: ¿Cuál es el MTTD para técnicas críticas en incidentes reales o simulados?
 - Q6.2: ¿Cuál es el MTTC y el MTTR para esas mismas técnicas?
 - Q6.3: ¿Cómo se comparan estos tiempos con objetivos nacionales o sectoriales?
- Metrics:
 - M6a: MTTD_Técnica_X (en horas/días).
 - M6b: MTTC_Técnica_X.
 - M6c: MTTR_Técnica_X.

PRAGMATIC

Criterio	Puntuación	Justificación breve
Predictivo	5	Fuertemente ligado a la probabilidad de contener ataques a tiempo.
Relevante	5	Central en resiliencia y continuidad.
Accionable	5	Permite fijar objetivos de mejora claros.
Genuino	4	Requiere registros de incidentes/ejercicios confiables.
Significativo	4	Con buena narrativa, muy comprensible para la dirección.
Preciso	3	Depende de cómo se defina inicio/fin de detección y contención.
Oportuno	3	Medición trimestral/anual suficiente para macro-visión.
Independiente	4	Complementa cobertura y calidad de detección.
Rentable	3	Puede ser laborioso, pero de alto valor.

Indicador 7 – Uso de CTI con mapeo ATT&CK y priorización ENISA

GQM

- Goal: Alinear capacidades nacionales con el panorama de amenazas real, utilizando CTI y prioridades de ENISA ETL 2025.[web:66][web:43]
- Questions:
 - Q7.1: ¿Qué porcentaje de organizaciones críticas consumen CTI con mapeo ATT&CK?
 - Q7.2: ¿Qué porcentaje prioriza sus casos de uso según TTP destacados por ENISA?
- Metrics:
 - M7a: %Organizaciones_Con_CTI_ATTCK.
 - M7b: %Organizaciones_Con_Prioridad_ENISA_TTP.

PRAGMATIC

Criterio	Puntuación	Justificación breve
Predictivo	4	La alineación con CTI reduce ceguera frente a nuevas campañas.
Relevante	4	Clave para sinergia país-UE.
Accionable	4	Puede motivar programas de CTI a escala nacional.
Genuino	3	Depende de la sinceridad en el uso real de la CTI.
Significativo	4	Fácil de explicar en foros de coordinación nacional.
Preciso	3	Requiere criterios claros de qué es "CTI con ATT&CK" y "priorizar".
Oportuno	3	Anual o bienal razonable.
Independiente	3	Relacionado con cobertura, pero centrado en insumos de inteligencia.
Rentable	4	Cuestionario / encuesta de bajo coste operacional.

Indicador 8 – Porcentaje de incidentes mapeados a ATT&CK y su distribución táctica

GQM

- Goal: Comprender el patrón real de TTP utilizados contra el país/sector, para orientar mejoras. [web:66]
- Questions:
- Q8.1: ¿Qué porcentaje de incidentes registrados a nivel nacional están mapeados a tácticas/técnicas ATT&CK?
- Q8.2: ¿Cuál es la distribución por táctica (Initial Access, Credential Access, etc.)?
- Metrics:
- M8a: %Incidentes_Mapeados_ATTCK.
- M8b: Distribución_%_Tácticas (vector de % por táctica).

PRAGMATIC

Criterio	Puntuación	Justificación breve
Predictivo	4	Permite anticipar dónde reforzar detección/prevención.
Relevante	5	Directamente vinculado a políticas nacionales de ciberseguridad.
Accionable	5	Orienta programas sectoriales y priorización de técnicas.
Genuino	3	Depende de calidad de reporting de incidentes.
Significativo	4	Muy útil para comunicar a decisores y opinión pública.
Preciso	3	Requiere criterios homogéneos de mapeo.
Oportuno	3	Actualización anual razonable.
Independiente	4	Complementa cobertura con uso real por adversarios.
Rentable	3	Depende de herramientas de gestión de incidentes.

Indicador 9 – Porcentaje de herramientas/servicios gestionados alineados con ATT&CK

GQM

- Goal: Asegurar que el ecosistema tecnológico de seguridad nacional (herramientas, MSSP) soporta MITRE ATT&CK de forma nativa y operativa.[web:16][web:23]
- Questions:
 - Q9.1: ¿Qué porcentaje de herramientas clave tiene soporte ATT&CK (dashboards, etiquetas, reglas)?
 - Q9.2: ¿Qué porcentaje de servicios gestionados reportan cobertura ATT&CK explícita?
- Metrics:
 - M9a: %Herramientas_Attck_Ready.
 - M9b: %Servicios_MSSP_Attck_Aligned.

PRAGMATIC

Criterio	Puntuación	Justificación breve
Predictivo	3	Indica potencial de medición futura y calidad de reporting.
Relevante	4	Clave para apalancar el ecosistema industrial.
Accionable	4	Permite condicionar compras y contratos.
Genuino	4	Basado en capacidades demostrables de herramientas/servicios.
Significativo	3	Entendible para decisiones de compra; menos para usuarios.
Preciso	4	Fácil de definir (check-list de capacidades).
Oportuno	4	Se puede actualizar cuando cambian contratos/tecnologías.
Independiente	3	Conectado pero distinto de métricas puramente operativas.
Rentable	4	Bajo coste si se integra en procesos de procurement.

Indicador 10 – Índice Global de Madurez ATT&CK (IGM)

GQM

- Goal: Disponer de una medida sintética de madurez ATT&CK a nivel organización/sector/país, para comparación y seguimiento temporal.
- Questions:
- Q10.1: ¿Cuál es la puntuación media ponderada en los bloques clave (gobierno, cobertura, tiempos, CTI, etc.)?
- Q10.2: ¿Cómo evoluciona el IGM en el tiempo y entre sectores?
- Metric:
- M10: $IGM = \sum(IGM_Bloque \times Peso_Bloque)$ en escala 0–5.

PRAGMATIC

Criterio	Puntuación	Justificación breve
Predictivo	3	Métrica agregada; más útil para seguimiento que predicción directa.
Relevante	4	Muy útil para comunicación macro.
Accionable	3	Requiere descomponer en bloques para acciones concretas.
Genuino	3	Depende de calidad de las métricas subyacentes.
Significativo	4	Fácil de comunicar (índice único).
Preciso	3	Precisión media; simplifica realidades complejas.
Oportuno	3	No necesita alta frecuencia (anual).
Independiente	2	Altamente dependiente de otros indicadores.
Rentable	4	Bajo coste una vez se miden los componentes.

Indicador 11 – ROI de iniciativas ATT&CK-driven

GQM

- Goal: Asegurar que las inversiones en iniciativas de mejora ATT&CK generan un retorno razonable en términos de reducción de riesgo.[web:50][web:53]
- Questions:
 - Q11.1: ¿Cuál es el coste de cada iniciativa (personas, herramientas, servicios)?
 - Q11.2: ¿Cuál es la reducción de riesgo esperada (basada en mejora de cobertura, tiempos, etc.)?
 - Q11.3: ¿Cuál es el ROI global por iniciativa y portafolio?
- Metric:
 - M11: $ROI = (Reducción_Riesgo_Esperado - Coste) / Coste$.

PRAGMATIC

Criterio	Puntuación	Justificación breve
Predictivo	4	Proyecta impacto económico de mejoras.
Relevante	5	Lenguaje natural para gobiernos y finanzas.
Accionable	5	Directamente vinculado a priorización de inversiones.
Genuino	3	Sensible a supuestos de modelización de riesgo.
Significativo	4	Alto impacto en foros de decisión.
Preciso	2	Difícil de estimar con precisión real.
Oportuno	3	Útil en grandes ciclos de planificación.
Independiente	3	Basado en otros indicadores, pero con foco económico.
Rentable	3	Requiere esfuerzo de modelización, pero aporta claridad.